

WEB APPLICATION SECURITY REVIEW

KifaruCart Customer & Admin Portals

OWASP-style non-intrusive web application security audit and architecture review

Table 1. Document Control

Attribute	Details
Organization	KifaruCart Global Ltd.
Document Title	Web Application Security Review: Customer & Admin Portals
Review Date	August 22, 2026
Target Systems	KifaruCart Web Portal (portal.kifarucart.example)
Assessment Type	Non-Intrusive Web Application Security Audit & Architecture Review
Lead Assessor	Senior Web Application Security Analyst
Overall Risk Rating	CRITICAL

Table of Contents

Executive Summary	3
1. Application Overview & Review Scope	3
1.1 Target Architecture & Modules	3
1.2 Audit Boundary & Scope	4
2. OWASP Top 10 (2021) Vulnerability Mapping Summary	4
3. Detailed Findings & Remediation Notes	5
3.1 WASR-001: Exposed Backup Files in Public Web Root	5
3.2 WASR-002: Insecure Direct File Access to Sensitive Uploads	5
3.3 WASR-003: Weak Session Handling & Invalidation Deficiencies	6
3.4 WASR-004: Missing Anti-CSRF Protection on Sensitive Endpoints	6
3.5 WASR-005: Insecure Direct Object Reference (IDOR) in Invoices & Tracking	7
3.6 WASR-006: Unsafe Document File Uploads	7
4. Secondary Audit Observations	8
5. Phased Remediation Roadmap	8
6. Portfolio Positioning Statement	9

List of Tables

Table 1. Document Control	1
Table 2. Target Architecture and Application Modules	3
Table 3. Audit Boundary and Scope	4
Table 4. OWASP Top 10 (2021) Vulnerability Mapping Summary	4
Table 5. Exposed Backup Files Evidence	5
Table 6. Insecure Direct File Access Evidence	5
Table 7. Session Handling Weaknesses	6
Table 8. Missing CSRF Protection Evidence	6
Table 9. Unsafe Document Upload Evidence	7
Table 10. Secondary Audit Observations	8
Table 11. Phased Remediation Roadmap	8

Executive Summary

A non-intrusive web application security review was conducted for KifaruCart Global Ltd.'s cross-border e-commerce and logistics platform. The audit evaluated the core customer-facing features, administrative portal workflows, identity and session management, and media/document processing endpoints.

The assessment revealed systemic vulnerabilities across multiple OWASP Top 10 (2021) categories. High-risk findings include publicly exposed web-root backup archives exposing API keys and database credentials, Insecure Direct Object References (IDOR) on financial and shipment endpoints, unauthenticated static access to sensitive customer PII and customs documents, weak session token lifecycle management, missing anti-CSRF protections on sensitive administrative actions, and unsafe document upload handling.

Immediate remediation is required to secure customer PII, prevent unauthorized access to administrative functions, stop data leakage, and protect payment and customs documentation.

1. Application Overview & Review Scope

1.1 Target Architecture & Modules

Table 2. Target Architecture and Application Modules

Module Name	Technical Functionality	Security Exposure Risk
Customer Portal	Handles customer registration, order placement, link submission, and profile updates.	High: customer PII and credential access
Admin Portal	Internal management interface for order operations, refund approvals, and shipment updates.	Critical: administrative authorization
Document Upload	Ingestion point for customer government IDs, purchase invoices, and customs clearance PDFs.	Critical: malicious uploads and remote code execution
Payment Module	Processing endpoint for payment receipts, transaction proofs, and invoice statuses.	High: financial data exposure
Shipment Tracking	Real-time movement tracking and physical delivery progress records.	Medium: order enumeration and information disclosure
User Account & Auth	Handles authentication, session generation, password resets, and session termination.	High: session hijacking and privilege escalation

1.2 Audit Boundary & Scope

Table 3. Audit Boundary and Scope

Audit Target / Area	In Scope?	Scope Rationale & Exclusions
Customer & Admin Portals	Yes	Full evaluation of login, session, workflow, and access control logic.
File Upload Endpoints	Yes	Assessment of file validation, storage architecture, and access policies.
Session & Cookie Controls	Yes	Inspection of cookie security flags, timeouts, and session invalidation.
Exposed Web-Root Files	Yes	Directory enumeration for exposed backups, archives, and .env configuration files.
Source Code Inspection	Partial	Focused static code and configuration snippet review.

Audit Target / Area	In Scope?	Scope Rationale & Exclusions
Third-Party Payment Gateways	No	Excluded third-party processing APIs and payment vendor backends.
External Merchant Sites	No	Out-of-scope third-party platforms such as Amazon, eBay, and Walmart.
Active Dynamic Exploitation	No	Non-intrusive structural audit; no live system exploitation.

2. OWASP Top 10 (2021) Vulnerability Mapping Summary

Table 4. OWASP Top 10 (2021) Vulnerability Mapping Summary

Finding ID	Flaw / Vulnerability Title	Primary OWASP Mapping	Severity
WASR-001	Exposed Backup Files in Public Web Root	A05:2021 - Security Misconfiguration / A01: Broken Access Control	Critical
WASR-002	Insecure Direct File Access to Sensitive Uploads	A01:2021 - Broken Access Control	Critical
WASR-003	Weak Session Handling & Invalidation Deficiencies	A07:2021 - Identification & Authentication Failures	High
WASR-004	Missing Anti-CSRF Tokens on Sensitive State Requests	A01:2021 - Broken Access Control (CSRF)	High
WASR-005	Insecure Direct Object Reference (IDOR) in Invoices	A01:2021 - Broken Access Control	Critical
WASR-006	Unrestricted / Unsafe Document File Uploads	A05:2021 - Security Misconfiguration (Unrestricted Upload)	High
WASR-007	Missing HTTP Security Hardening Headers	A05:2021 - Security Misconfiguration	Medium
WASR-008	Verbose Error Messages & Stack Trace Disclosure	A05:2021 - Security Misconfiguration	Medium

3. Detailed Findings & Remediation Notes

3.1 WASR-001: Exposed Backup Files in Public Web Root

Severity: Critical

Description: Database dumps, compressed source code archives, and legacy configuration backups are accessible within the public web directory, including the /backups/ folder and application root.

Table 5. Exposed Backup Files Evidence

Exposed Resource URL	Disclosed Sensitive Artifacts
https://portal.kifarucart.example/backups/kifarucart-db-2026-08.sql	Plaintext database dump, customer PII, and order histories.
https://portal.kifarucart.example/backup-old.zip	Application source code, internal routing, and logic functions.
https://portal.kifarucart.example/.env.bak	Database passwords, private API keys, and secret signing keys.

Risk impact: Unauthenticated attackers could download sensitive configuration files, compromise database credentials, extract private customer records, and review application source code for further exploitation.

- Immediately purge all archive formats such as .sql, .bak, .zip, .tar.gz, and .env.bak from public web directories.

- Store backup archives in isolated, non-public storage with strict IAM access controls.
- Configure Nginx/Apache rules to deny public access to sensitive file extensions.
- Rotate exposed secrets, database passwords, and external API keys.

3.2 WASR-002: Insecure Direct File Access to Sensitive Uploads

Severity: Critical

Description: Uploaded customer documents such as tax forms, government IDs, and invoices are stored in predictable web paths without active session or permission checks.

Table 6. Insecure Direct File Access Evidence

Target Resource Path	Predictable Element	Observed Security Control
/uploads/customs/2026/receipt_10451.pdf	Sequential numeric ID (10451)	None: direct unauthenticated access allowed.
/uploads/customs/2026/receipt_10452.pdf	Sequential numeric ID (10452)	None: bypasses session check entirely.

Risk impact: An attacker could increment sequential document numbers to systematically view or scrape private customer identity cards, purchase receipts, and customs documentation.

- Move uploaded file directories completely outside the public web server document root.
- Implement an authenticated streaming controller route, such as /api/documents/download?id=<GUID>, that checks object ownership before returning file streams.
- Use short-lived signed URLs only after authorization is confirmed.

3.3 WASR-003: Weak Session Handling & Invalidation Deficiencies

Severity: High

Description: User sessions remain active for extended periods, cookies lack recommended security flags, and server-side session invalidation fails upon password resets or logouts.

Table 7. Session Handling Weaknesses

Session Property	Observed Configuration	Standard Security Benchmark
Inactivity Timeout	> 24 hours	15-30 minutes maximum for sensitive portals
Logout Invalidation	Session token remains active on server	Complete server-side token destruction
Password Reset	Legacy sessions remain valid	Global revocation of all active sessions
Cookie Attributes	HttpOnly, Secure, and SameSite flags missing	Mandatory Secure, HttpOnly, and SameSite=Strict or Lax

Risk impact: Weak session controls enable persistent session hijacking through XSS, network sniffing, or shared terminal access, allowing attackers to maintain access after password reset.

- Set session cookies with HttpOnly, Secure, and SameSite=Strict or Lax attributes.
- Enforce automated session expiration after 15 to 30 minutes of inactivity.
- Regenerate session tokens immediately after login, privilege change, and password reset.
- Ensure explicit server-side session invalidation upon logout.

3.4 WASR-004: Missing Anti-CSRF Protection on Sensitive Endpoints

Severity: High

Description: State-changing POST requests within customer and admin portals process updates without validating anti-CSRF tokens.

Table 8. Missing CSRF Protection Evidence

Vulnerable Endpoint URI	Request Type	Unprotected Administrative / Customer State Action
/account/update-address	POST	Modifies account delivery and shipping destination.
/refund/request	POST	Triggers customer account balance refund issuance.
/admin/shipment/update-status	POST	Changes logistics routing state in Admin Portal.
/account/change-phone	POST	Changes identity verification phone contact.

Risk impact: Attackers could trick authenticated users into visiting malicious sites that execute unauthorized state changes using active browser cookies.

- Implement unique, cryptographically secure anti-CSRF tokens for all state-changing operations such as POST, PUT, and DELETE.
- Enforce strict server-side validation before request execution.
- Require re-authentication for high-risk actions such as address modification and refund requests.

3.5 WASR-005: Insecure Direct Object Reference (IDOR) in Invoices & Tracking

Severity: Critical

Description: The portal uses predictable sequential identifiers for invoice and order endpoints without verifying whether the requesting user owns the requested record.

HTTP GET /customer/invoice/10045 -> 200 OK (User A views own invoice)
HTTP GET /customer/invoice/10046 -> 200 OK (User A views User B's invoice) [IDOR]
HTTP GET /tracking/order/8301 -> 200 OK (User A views own tracking)
HTTP GET /tracking/order/8302 -> 200 OK (User A views User B's shipment) [IDOR]

Risk impact: Attackers can systematically scrape invoice records, payment details, full names, home addresses, customs manifest details, and purchase values.

- Enforce strict context-aware, object-level authorization checks in backend controllers, such as User.ID == Record.OwnerID.
- Replace sequential numeric identifiers with UUIDv4 or similar non-sequential identifiers as a secondary control.
- Add automated integration tests to verify access control on all record requests.

3.6 WASR-006: Unsafe Document File Uploads

Severity: High

Description: The document upload module fails to validate file extension formats, magic byte headers, file size limits, or storage execution privileges.

Table 9. Unsafe Document Upload Evidence

Test Case / Condition	Observed Application Behavior	Security Risk
-----------------------	-------------------------------	---------------

Test Case / Condition	Observed Application Behavior	Security Risk
Extension substitution (.php -> .jpg)	File accepted into system directory	Web shell upload staging.
Double extension (receipt.pdf.exe)	File accepted without rejection	Client-side execution delivery.
Oversized payload upload	File accepted without size enforcement	Denial of Service through storage exhaustion.
Storage directory location	Saved directly to /uploads/ web root	Direct web shell execution.
Anti-malware scanning	Not implemented	Malware distribution risk.

Risk impact: Attackers could upload web shell scripts or malicious files to execute arbitrary commands on the web server, causing system compromise, data theft, or lateral network movement.

- Implement explicit extension allowlisting, enforcing only approved formats such as .pdf, .png, and .jpg.
- Validate file content through magic byte inspection rather than relying only on MIME headers or extensions.
- Store uploaded files outside the public web root and strip execution permissions from storage volumes.
- Integrate automated antivirus scanning, such as ClamAV, into file upload pipelines.

4. Secondary Audit Observations

Table 10. Secondary Audit Observations

Observation ID	Identified Deficiency	Severity	Technical Remediation Note
OBS-001	Missing Content Security Policy (CSP)	Medium	Implement strict Content-Security-Policy HTTP header to mitigate XSS.
OBS-002	Missing clickjacking protections	Medium	Deploy X-Frame-Options: DENY and frame-ancestors 'none' rules.
OBS-003	Verbose framework stack traces	Medium	Disable debug mode in production and replace detailed errors with generic user error pages.
OBS-004	Publicly accessible Admin Portal	High	Restrict /admin/ routes through IP allowlisting, VPN enforcement, or Zero Trust Network Access.
OBS-005	Prolonged password reset token validity	Medium	Reduce password reset link expiration to 15 minutes and enforce single-use invalidation.

5. Phased Remediation Roadmap

Table 11. Phased Remediation Roadmap

Phase	Timeline	Remediation Action	Related Finding
Phase 1: Immediate Containment	0-30 days	Purge web-root backups and rotate exposed secrets.	WASR-001
Phase 1: Immediate Containment	0-30 days	Relocate uploaded file directories outside the public root.	WASR-002
Phase 1: Immediate Containment	0-30 days	Implement object-level authorization for invoices and shipments.	WASR-005
Phase 1: Immediate Containment	0-30 days	Enforce file extension allowlists and magic byte verification.	WASR-006
Phase 1: Immediate Containment	0-30 days	Apply anti-CSRF token validation to state-changing forms.	WASR-004
Phase 2: Short-Term Hardening	31-60 days	Apply secure cookie attributes: Secure, HttpOnly, and SameSite.	WASR-003
Phase 2: Short-Term Hardening	31-60 days	Enforce session timeouts and revocation after password reset.	WASR-003

Phase	Timeline	Remediation Action	Related Finding
Phase 2: Short-Term Hardening	31-60 days	Deploy HTTP hardening headers such as CSP and X-Frame-Options.	OBS-001 / OBS-002
Phase 2: Short-Term Hardening	31-60 days	Restrict Admin Portal exposure through Zero Trust or VPN.	OBS-004
Phase 3: Program Integration	61-90 days	Implement automated SAST, DAST, and dependency scanning in CI/CD.	Program control
Phase 3: Program Integration	61-90 days	Conduct secure code training on OWASP Top 10 risks for development teams.	Program control
Phase 3: Program Integration	61-90 days	Establish recurring quarterly web application security audits.	Program control

6. Portfolio Positioning Statement

Conducted an OWASP-style web application security audit of KifaruCart Global Ltd.'s e-commerce and logistics portals. Evaluated application security architecture against OWASP Top 10 (2021) standards, discovering critical vulnerabilities involving exposed web-root backups, Insecure Direct Object References (IDOR), insecure direct document access, weak session management, missing anti-CSRF protections, and unsafe upload handling. Authored detailed technical analysis, evidence profiles, and a phased remediation roadmap for development and IT infrastructure teams.